Networking Academy

Azura Rizky Annisa (24/535715/SV/24290)

Lab - Investigating an Attack on a Windows Host

Objectives

In this lab you will:

Part 1: Investigate the Attack with Sguil

Part 2: Use Kibana to Investigate Alerts

This lab is based on an exercise from the website malware-traffic-analysis.net which is an excellent resource for learning how to analyze network and host attacks. Thanks to brad@malware-traffic-analysis.net for permission to use materials from his site.

Background / Scenario

In March 2019, network security monitoring tools alerted that a Windows computer on the network was infected with malware. In this task, you are to investigate the alerts and answer the following questions:

- What was the specific time of the attack on 2019-03-19?
- Which Windows host computer was infected? Who was the user?
- What was the computer infected with?

Required Resources

- Security Onion virtual machine
- Internet access

Instructions

Part 1: Investigate the Attack with Sguil

In Part 1, you will use Sguil to check the IDS alerts and gather more information about the series of events related to an attack on 3-19-2019.

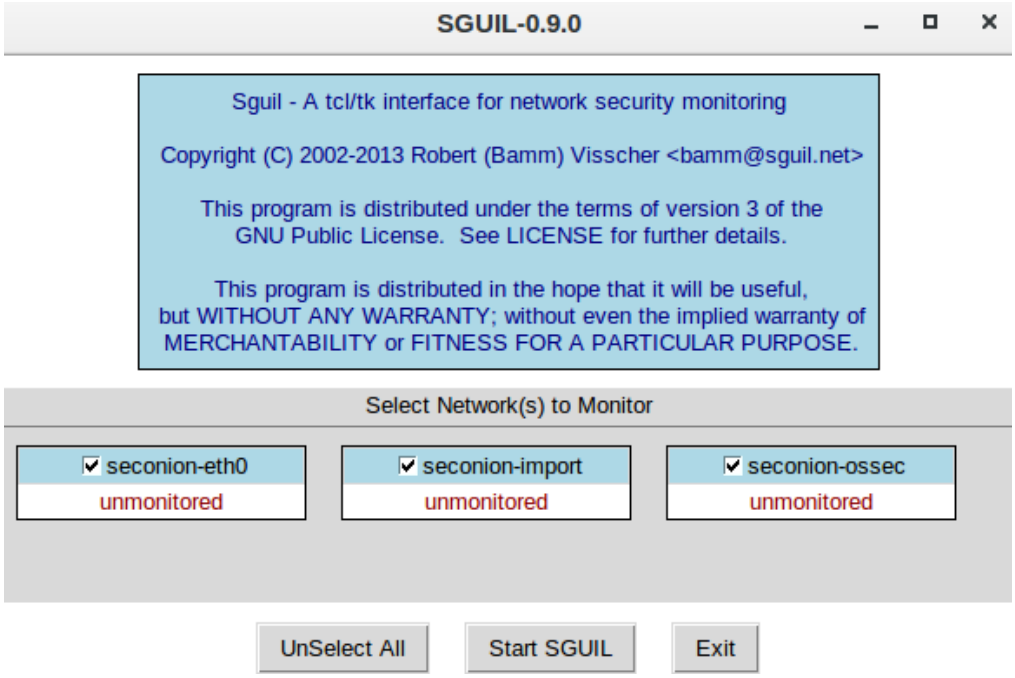
Note: The alert IDs used in this lab are for example only. The alert IDs on your VM may be different.

Step 1: Open Sguil and locate the alerts on 3-19-2019.

a. Login to Security Onion VM with the **analyst** username and **cyberops** password.

b. Launch Sguil from the desktop. Login with username **analyst** and password **cyberops**. Click **Select All** and **Start Sguil** to view all the alerts generated by the network sensors.

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public



c. Locate the group of alerts from 19 March 2019.

According to Sguil, what are the timestamps for the first and last of the alerts that occurred on 3-19-2019? What is interesting about the timestamps of all the alerts on 3-19-2019?

RT	1	seconion-...	5.439	2019-03-19 01:45:03	10.0.90.215	52609	10.0.90.9	53	17	ET POLICY DNS Update
RT	2	seconion-...	5.440	2019-03-19 01:47:04	10.0.90.215	49204	209.141.34.8	80	6	ET INFO Executable Do
RT	1	seconion-...	5.441	2019-03-19 01:47:04	10.0.90.215	49204	209.141.34.8	80	6	ET CURRENT_EVENTS
RT	2	seconion-...	5.442	2019-03-19 01:47:04	209.141.34.8	80	10.0.90.215	49204	6	ET CURRENT_EVENTS
RT	12	seconion-...	5.444	2019-03-19 01:47:04	209.141.34.8	80	10.0.90.215	49204	6	ET CURRENT_EVENTS
RT	12	seconion-...	5.456	2019-03-19 01:47:04	209.141.34.8	80	10.0.90.215	49204	6	ET INFO SUSPICIOUS
RT	12	seconion-...	5.468	2019-03-19 01:47:04	209.141.34.8	80	10.0.90.215	49204	6	ET POLICY PE EXE or
RT	404	seconion-...	5.480	2019-03-19 01:49:45	10.0.90.215	49205	103.1.184.108	2404	6	ET TROJAN Remcos RA
RT	1	seconion-...	5.482	2019-03-19 01:49:46	10.0.90.215	49206	217.23.14.81	80	6	ET CURRENT_EVENTS
RT	2	seconion-...	5.483	2019-03-19 01:49:46	217.23.14.81	80	10.0.90.215	49206	6	ET CURRENT_EVENTS
RT	12	seconion-...	5.485	2019-03-19 01:49:46	217.23.14.81	80	10.0.90.215	49206	6	ET INFO EXE - Served
RT	12	seconion-...	5.497	2019-03-19 01:49:46	217.23.14.81	80	10.0.90.215	49206	6	ET INFO Packed Execut
RT	12	seconion-...	5.509	2019-03-19 01:49:46	217.23.14.81	80	10.0.90.215	49206	6	ET CURRENT_EVENTS
RT	12	seconion-...	5.521	2019-03-19 01:49:46	217.23.14.81	80	10.0.90.215	49206	6	ET CURRENT_EVENTS
RT	12	seconion-...	5.533	2019-03-19 01:49:46	217.23.14.81	80	10.0.90.215	49206	6	ET POLICY Terse Name
RT	16	seconion-...	5.571	2019-03-19 02:03:24	31.22.4.176	3389	10.0.90.215	49213	6	ET TROJAN ABUSE.CH
RT	13	seconion-...	5.589	2019-03-19 02:08:17	203.45.1.75	443	10.0.90.215	49218	6	ET TROJAN ABUSE.CH
RT	3	seconion-...	5.942	2019-03-19 04:54:34	115.112.43.81	443	10.0.90.215	49289	6	ET TROJAN ABUSE.CH

Peringatan pertama; 19-03-2019 01:45:03

Peringatan terakhir: 19-03-2019 04:54:34

Peringatan tersebut menunjukkan adanya aktivitas mencurigakan selama lebih dari 3 jam.

Step 2: Review the alerts in detail.

a. In Sguil, click the first of the alerts on 3-19-2019 (Alert ID 5.439). Make sure to check the **Show Packet Data** and **Show Rule** checkboxes to examine the packet header information and the IDS signature rule

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

related to the alert. Right on the **Alert ID** and pivot to Wireshark. Based on the information derived from this initial alert answer the following questions:

What was the source IP address and port number and destination IP address and port number?

```
Frame 1: 161 bytes on wire (1288 bits), 161 bytes captured (1288 bits)
Ethernet II, Src: 64:32:a8:57:2b:42, Dst: a4:1f:72:c2:09:6a
Internet Protocol Version 4, Src: 10.0.90.215, Dst: 10.0.90.9
User Datagram Protocol, Src Port: 52609, Dst Port: 53
Domain Name System (query)
```

Src IP address: 10.0.90.215, port number: 52609

Dst IP address: 10.0.90.9, port number: 53

What type of protocol and request or response was involved?
UDP, DNS

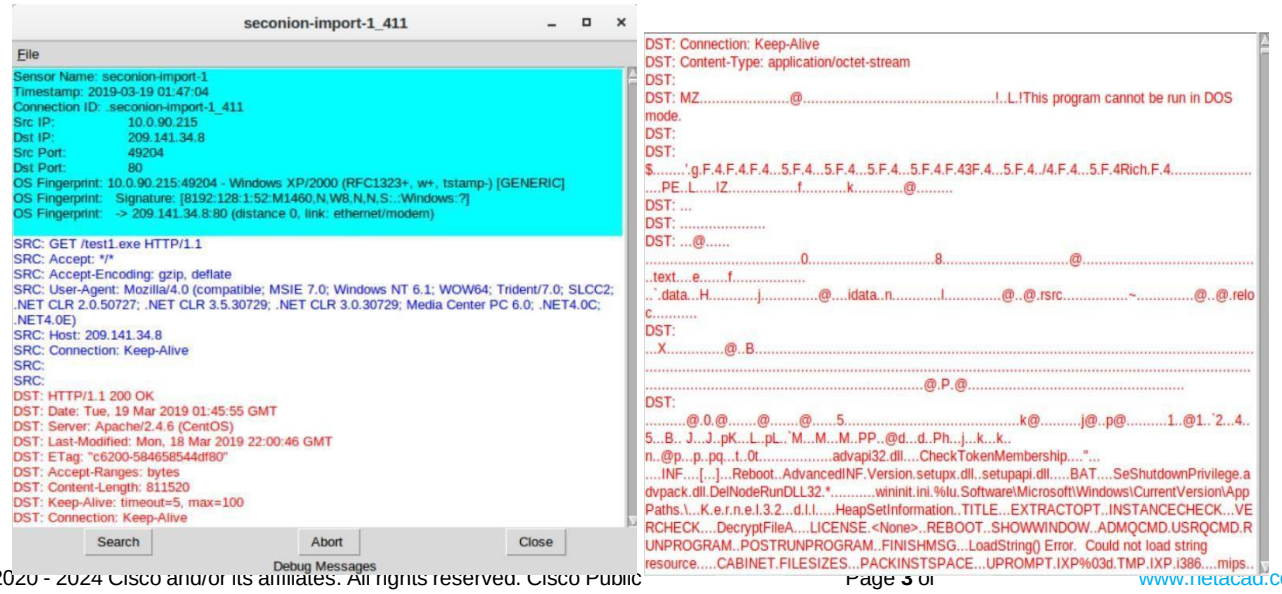
What is the IDS alert and message?

```
alert udp $EXTERNAL_NET any -> $HOME_NET 53 (msg:"ET POLICY DNS Update From External
net"; byte_test:1,!&,128,2; byte_test:1,!&,64,2; byte_test:1,&,32,2; byte_test:1,!&,16,2;
```

Do you think this alert was the result of an IDS misconfiguration or a legitimate suspicious communication?
Miskonfigurasi pada IDS.

What is the hostname, domain name, and IP address of the source host in the DNS update?
Hostname: Bobby-Tiger-PC
Domain name: littletigers.info
Src host: 10.0.90.215

b. In Sguil, select the second of the alerts on 3-19-2019. Right click the Alert ID 5.440 and select **Transcript**.



© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

www.netacad.com

From the transcript answer the following questions:

What is the source and destination IP address and port numbers?

Src IP:	10.0.90.215
Dst IP:	209.141.34.8
Src Port:	49204
Dst Port:	80

Looking at the request (blue) what was the request for?
SRC: GET /test1.exe

Looking at the reply (red) many files will reveal their file signature in the initial few characters of the file when viewed as text. File signatures help identify the type of file that is represented. Use a web browser to search for a list of common file signatures.

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

What is the initial few characters of the file file. Search for this file signature to find out what type of file was downloaded in the data?
MZ

c. Close the transcript. Use Wireshark to export the executable file for malware analysis (**File** > **Export Objects** > **HTTP…**). Save the file to the analyst's home folder.

d. Open a terminal in Security Onion VM and create a SHA256 hash from the exported file. Use the following command:

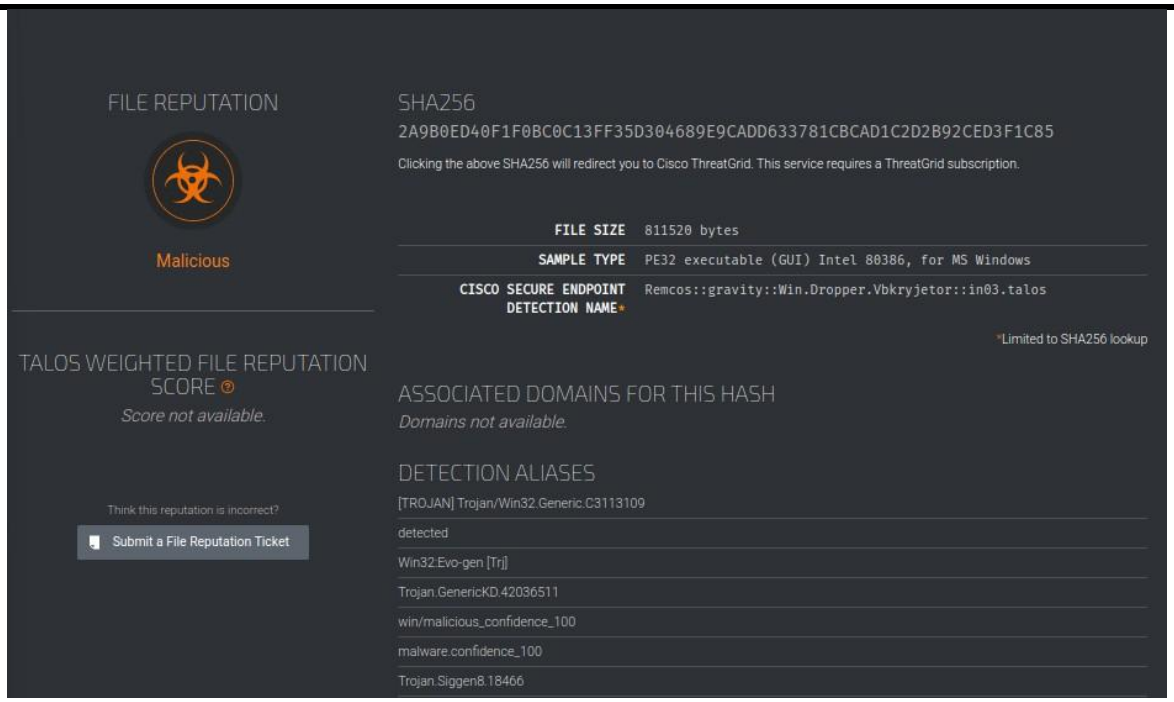
```
analyst@SecOnion:~$ sha256sum test1.exe
2a9b0ed40f1f0bc0c13ff35d304689e9cadd633781cbcad1c2d2b92ced3f1c85  test1.exe
```

e. Copy the file hash and submit it to the Cisco Talos file reputation center at https://talosintelligence.com/talos_file_reputation.



Did Talos recognize the file hash and identify it as malware? If so, what kind of malware?

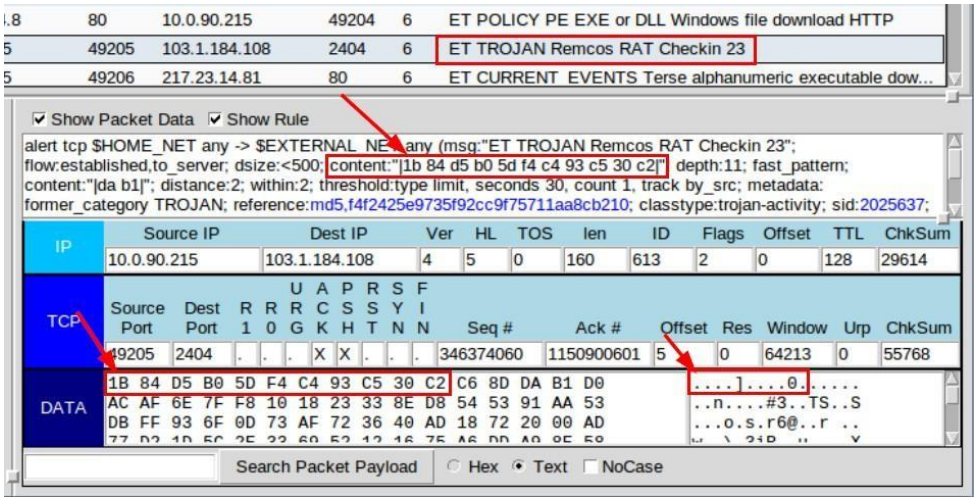
© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public



Trojan /Win32

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

f. In Sguil select the alert with **Alert ID 5.480** and the **Event Message** Remcos RAT Checkin 23. Notice that the IDS signature has detected the Remcos RAT based on the binary hex codes at the beginning of communication.



g. Right click the Alert ID and select **Transcript**. Scroll through the transcript and answer the following questions:

What is the destination port of the communication? Is it a well-known port?

2404, tidak terlalu diketahui

Is the communication readable or is it encrypted?
encrypted

Do some online research on Remcos RAT Checkin 23. What does Remcos stand for?
Remote control and surveillance software

What type of communication do you think was being transmitted?
Keylogger yang merekam data keystroke kita

What type of encryption and obfuscation was used to bypass detection?
Remcos RAT

h. Using Sguil and the remaining alerts from 3-19-2019, locate the second executable file that was downloaded and check to see if it is known malware.

What Alert IDs alert to a second executable file being downloaded?

5.483

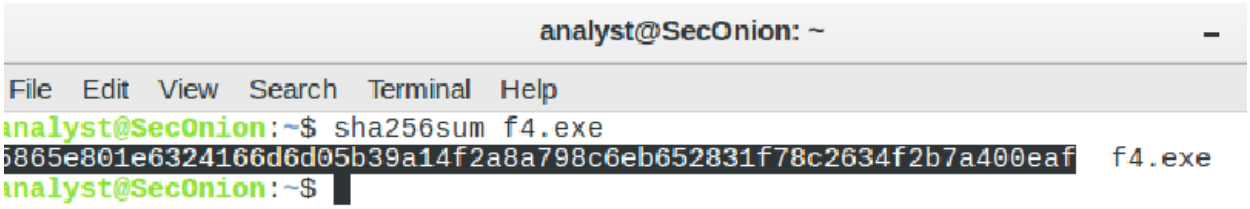
From which server IP address and port number was the file downloaded from?
Dst: 217.23.14.81
Port: 80

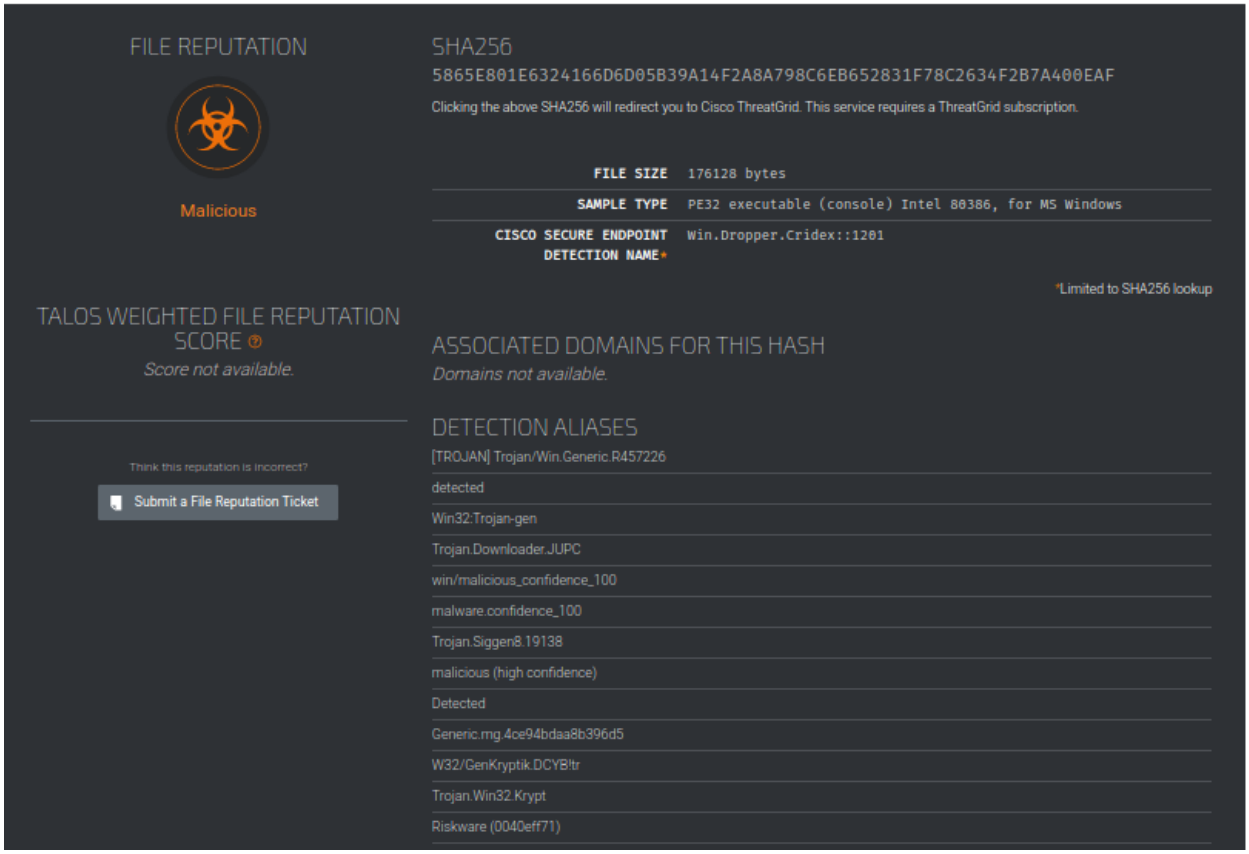
© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

What is the name of the file that was downloaded?

Filename
f4.exe

Create a SHA256 hash of the file and submit the hash online at Cisco Talos File Reputation Center to see if it matches known malware. Is the executable file known malware and if so, what type? What is the AMP DETECTION NAME?





PE32 executable(console)
Win.Dropper.Cridex::1201

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

i. Examine the remaining three alerts from 3-19-2019 by looking at the header information in Show Packet Data, the IDS signature in Show Rule, and the Alert ID Transcripts.

How are all three alerts related?

Ketiga alerts tersebut encrypted

j. Even though you have examined all the alerts in Sguil related to an attack on a Windows host on 3-19-2019, there may be additional related information available in Kibana. Close Sguil and launch Kibana from the desktop.

Part 2: Use Kibana to Investigate Alerts

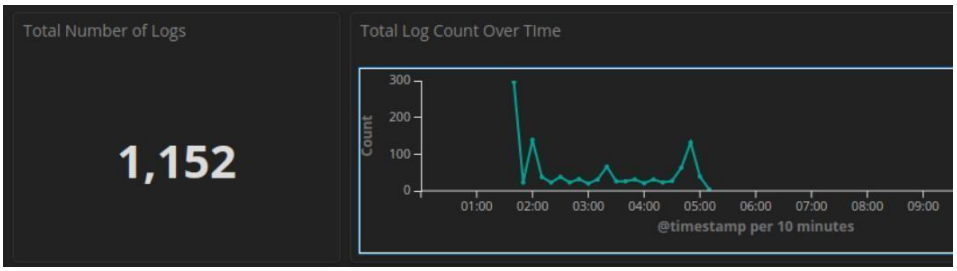
In Part 2, use Kibana to further investigate the attack on 3-19-2019.

Step 1: Open Kibana and narrow the timeframe.

a. Login to Kibana with the **analyst** username and **cyberops** password.

b. Open Kibana (username **analyst** and password **cyberops**), click **Last 24 Hours** and the **Absolute** time range tab to change the time range to March 1, 2019 to March 31, 2019.

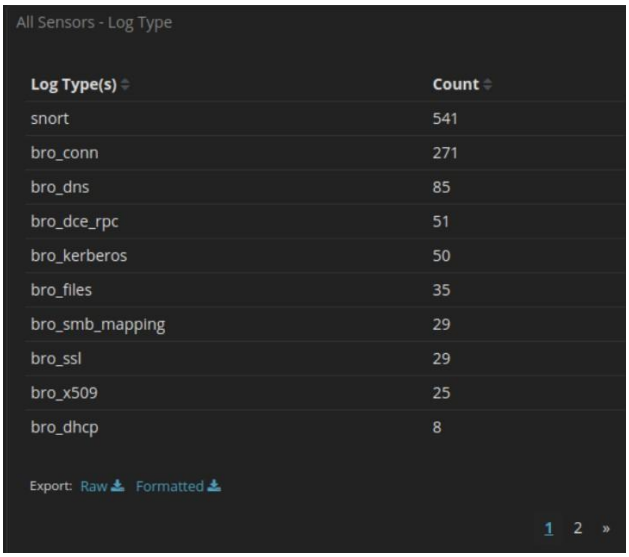
c. The **Total Log Count Over Time** timeline will show an event on March 19. Click that event to narrow the focus to the specific time range of the attack.



© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

Step 2: Review the alerts in the narrowed timeframe.

a. In the Kibana dashboard scroll down to the **All Sensors - Log Type** visualization. Review both pages and note the variety of log types related to this attack.

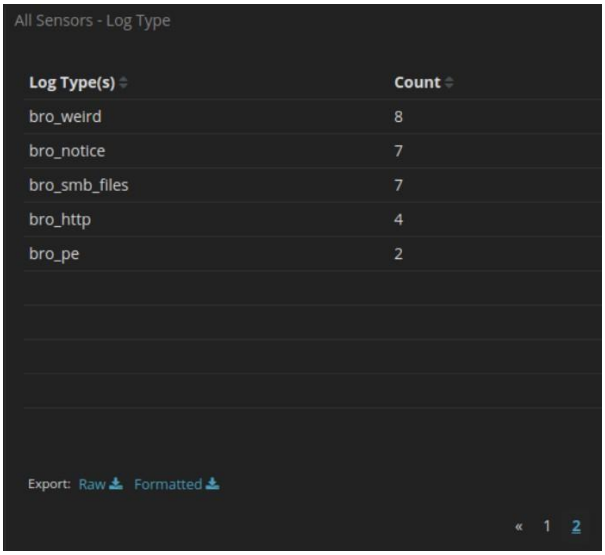


All Sensors - Log Type

Log Type(s)	Count
snort	541
bro_conn	271
bro_dns	85
bro_dce_rpc	51
bro_kerberos	50
bro_files	35
bro_smb_mapping	29
bro_ssl	29
bro_x509	25
bro_dhcp	8

Export: Raw Formatted

1 2 »



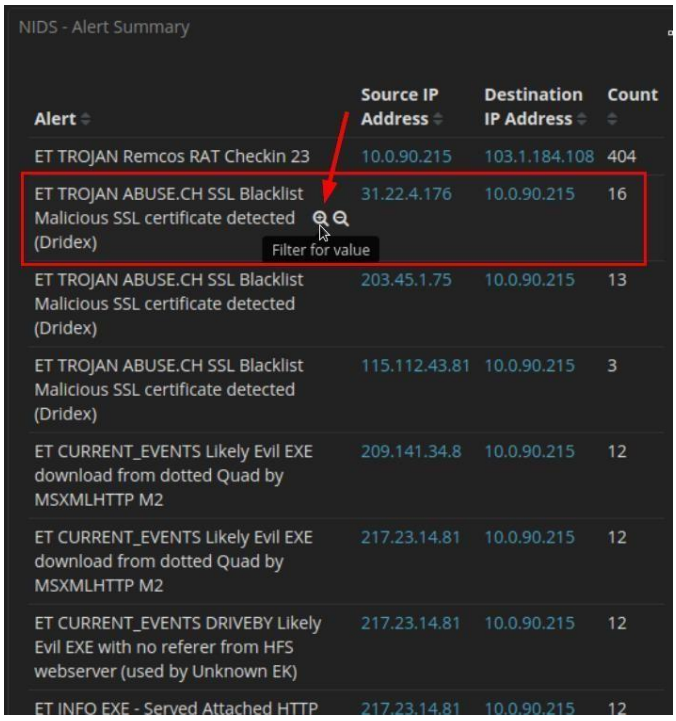
All Sensors - Log Type

Log Type(s)	Count
bro_weird	8
bro_notice	7
bro_smb_files	7
bro_http	4
bro_pe	2

Export: Raw Formatted

« 1 2

b. Scroll down and notice that the NIDS Alert Summary in Kibana has many of the same IDS alerts as listed in Sguil. Click the magnifier to filter on the second alert ET TROJAN ABUSE.CH SSL Blacklist Malicious SSL certificate detected (Dridex) from Source IP Address 31.22.4.176.



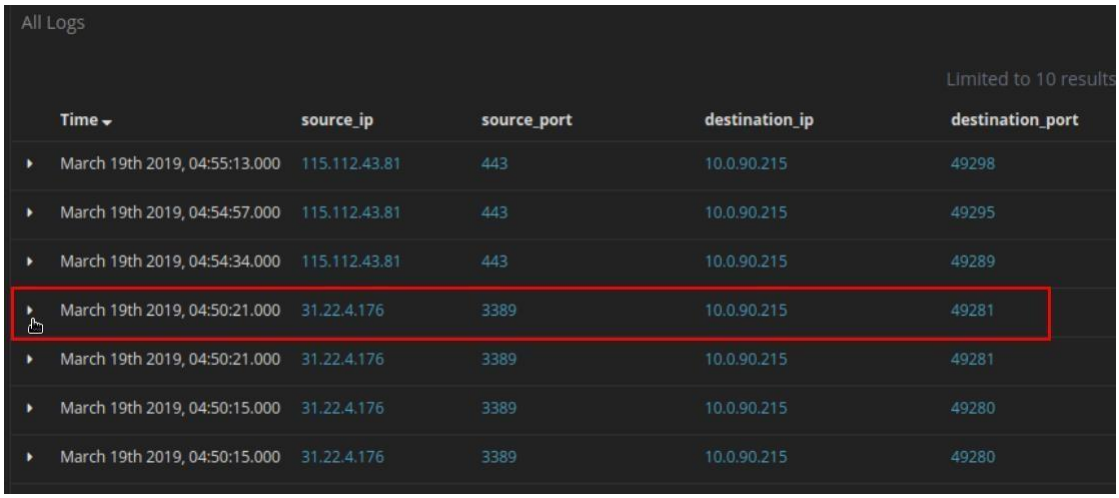
NIDS - Alert Summary

Alert	Source IP Address	Destination IP Address	Count
ET TROJAN Remcos RAT Checkin 23	10.0.90.215	103.1.184.108	404
ET TROJAN ABUSE.CH SSL Blacklist Malicious SSL certificate detected (Dridex)	31.22.4.176	10.0.90.215	16
ET TROJAN ABUSE.CH SSL Blacklist Malicious SSL certificate detected (Dridex)	203.45.1.75	10.0.90.215	13
ET TROJAN ABUSE.CH SSL Blacklist Malicious SSL certificate detected (Dridex)	115.112.43.81	10.0.90.215	3
ET CURRENT_EVENTS Likely Evil EXE download from dotted Quad by MSXMLHTTP M2	209.141.34.8	10.0.90.215	12
ET CURRENT_EVENTS Likely Evil EXE download from dotted Quad by MSXMLHTTP M2	217.23.14.81	10.0.90.215	12
ET CURRENT_EVENTS DRIVEBY Likely Evil EXE with no referer from HFS webserver (used by Unknown EK)	217.23.14.81	10.0.90.215	12
ET INFO EXE - Served Attached HTTP	217.23.14.81	10.0.90.215	12

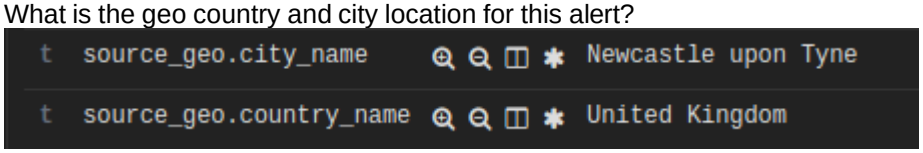
Filter for value

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

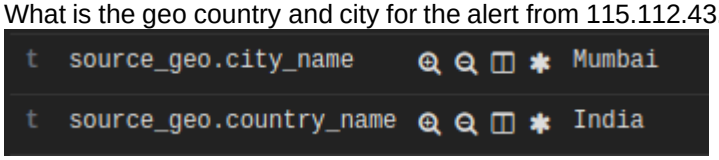
c. Scroll down to All Logs and click the arrow to expand the first log in the list with source IP address 31.22.4.176.



What is the geo country and city location for this alert?

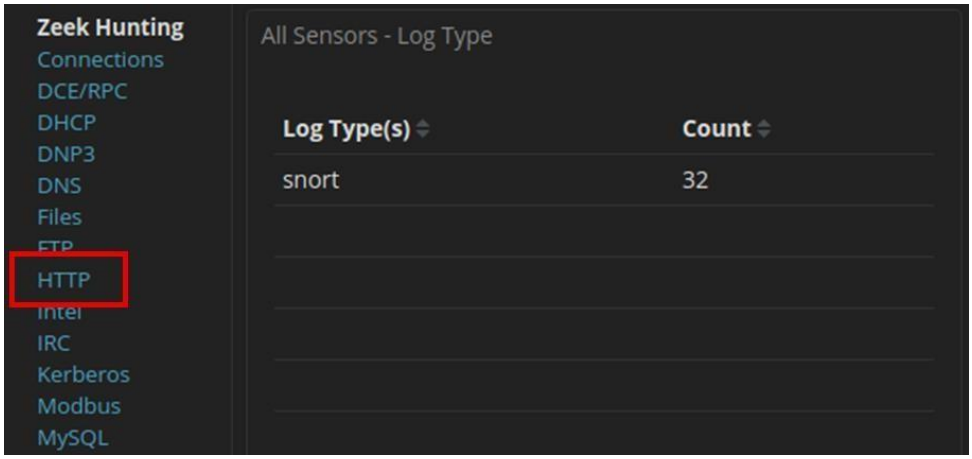


What is the geo country and city for the alert from 115.112.43.81?



d. Scroll back to the top of the page and click the Home link under Navigation.

e. Earlier we noted log types like bro_http listed in the Home dashboard. You can filter for the various log type but the built-in dashboards will probably have more information. Scroll back to the top of the page and click **HTTP** in dashboard link under Zeek Hunting in Navigation.

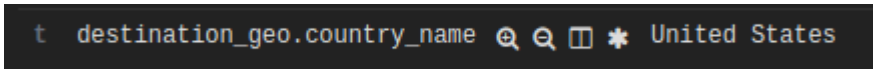


f. Scroll through the HTTP dashboard taking notice of the information presented and answer the following questions:

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

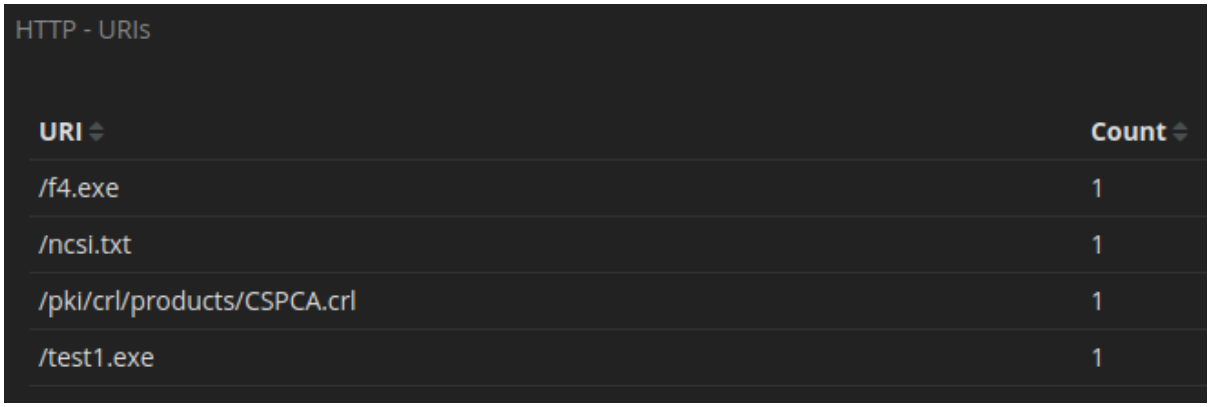
What is the Log Count in the HTTP dashboard? From what countries?

4





What are the URIs for the files that were downloaded?



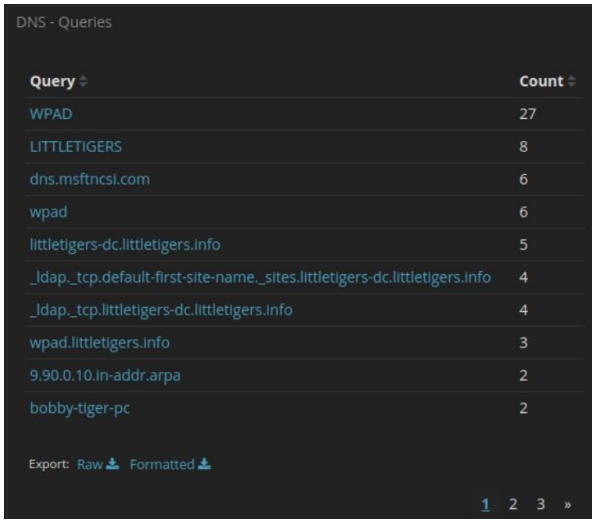
© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

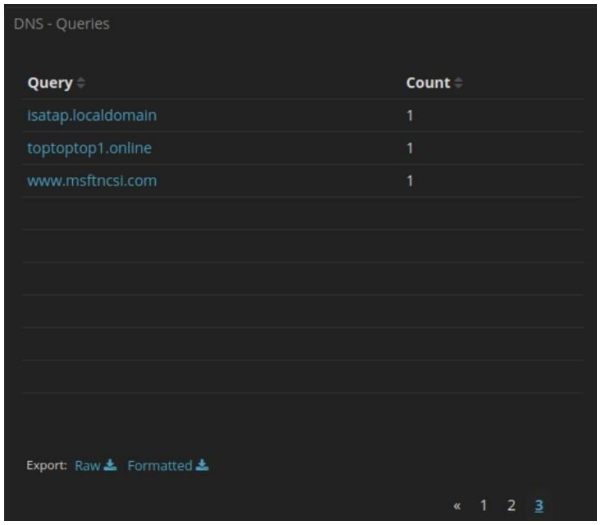
g. Match the **HTTP - URIs** to the **HTTP - Sites** on the dashboard.

What are the CSPCA.crl and ncsi.txt files related to? Use a web browser and a search engine for additional information.

CSPCA.crl adalah file Certificate Revocation List (CRL) yang diminta (diunduh) oleh sistem dari server Microsoft sebagai bagian dari mekanisme Public Key Infrastructure untuk memverifikasi apakah suatu sertifikat digital masih valid atau sudah dicabut, sedangkan ncsi.txt adalah file yang digunakan oleh fitur Network Connectivity Status Indicator di Windows untuk melakukan self-test koneksi internet dengan cara mengakses file tersebut dari server Microsoft guna memastikan perangkat benar-benar terhubung ke internet; keduanya merupakan aktivitas normal sistem operasi dan bukan indikasi malware.

h. Scroll back to the top of the web page and under Navigation - Zeek Hunting click **DNS**. Scroll to the DNS Queries visualization. Notice page 1 and page 3 of the DNS queries.





Do any of the domains seem potentially unsafe? Try submitting the URL toptoptop1.online to virustotal.com. What is the result?
Terindikasi berbahaya

i. For further investigation and curiosity, try examining the following Zeek Hunting dashboards:

DCE/RPC - for information about the Windows network remote procedures and resources involved

Kerberos – for information on the hostnames, and domain names that were used

PE – for information on the portable executables

SSL and x.509 – for information on the security certificate names and countries that were used

SMB – for more information on the SMB shares on the littletigers network

Weird – for protocol and service anomalies and malformed communications

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public